Summary of Book2 Sans 401

Endpoint Detection and Response. It's a type of cybersecurity technology designed to monitor, detect, and respond to suspicious activity and threats on endpoint devices (like laptops, desktops, servers, and mobile devices).

D Preventive measures (firewalls, hardening, …)
i Detective measures (IDS, EDR, Logs, …)
D Deterrent measures (Guard, …)

Perimeter Security: Focuses on securing the borders of a network, using tools like firewalls, proxy servers, and anti-DDoS appliances. This acts as a barrier between your organization and external, untrusted networks, providing a first line of defense.

Network Security: Aims to protect the internal network, often through methods like network segmentation and network access control. This helps to limit the spread of threats inside the organization.

Host Security: Involves hardening endpoints and servers by securely configuring systems, scanning for vulnerabilities, installing anti-malware software, and using application control solutions. A key reference for hardening configurations is the CIS benchmarks.

Application Security: Ensures secure software development by implementing measures like authentication controls, input validation, and buffer overflow protections. The goal is to minimize vulnerabilities within the applications themselves.

Data Security: Focuses on protecting data through techniques like encryption and data classification, ensuring sensitive data is handled securely based on its level of sensitivity.

Confidentiality (vs. Disclosure)

What it means: Ensuring that sensitive information is only accessible to authorized people or organizations.
Integrity (vs. Alteration)

What it means: Ensuring that data remains authentic and complete—it hasn't been tampered with or altered in unauthorized ways.
3. Availability (vs. Destruction)

What it means: Ensuring that data and systems are accessible when needed by authorized users.

Four basic approaches:
Uniform
Protection

Protected
Enclaves

Information-Centric

Vector
Oriented

Uniform Protection Defense-in-Depth
This is the most common approach to DiD. In this setup, all parts
of the organization receive equal protection and are treated the same
Firewalls
VPN
IDS
Antivirus
Patching

Uniform Protection:
Uniform Protection treats all systems in the organization as equally important, offering no special consideration or protection to critical assets like intellectual property. This approach can leave the network more vulnerable, especially to malicious insiders, since systems aren't categorized or separated based on their importance.

Vector-Oriented Defense-in-Depth is about identifying potential pathways (vectors) through which attackers can exploit vulnerabilities, then blocking or mitigating those vectors. This reduces the overall risk, even when vulnerabilities cannot be completely removed.

A firewall is like a huge wall around your network.

The wall has doors (called ports) with numbers.

Each door can only open if there's a rule saying traffic is allowed.

Ingress = traffic coming in.

Egress = traffic going out.

On a physical network (on-premise):

You'd put a firewall between every VLAN (network segment).

You must configure all the rules so devices know what traffic is allowed.

Problem: if the firewall breaks, devices can't talk → so you need a backup firewall.

In the cloud:

Instead of physical firewalls, you use Security Groups.

An HTTP flood attack is a type of DoS/DDoS attack that targets a web server by sending a huge number of HTTP requests (the same kind your browser makes when you load a webpage).

Key idea:

The attacker doesn't send garbage traffic — instead, they send real-looking requests like

GET /index.html (asking for a page)

POST /login (submitting a form)

Because these requests look legitimate, they are harder to filter out.

Goal:

Overwhelm the web server's CPU, memory, or bandwidth so it becomes too busy to serve real users.

Basically, the attacker forces the server to spend all its time answering fake "customers."

Web Application Firewall (WAF)
Let's say your organization has a web application that can be accessed from the internet, and you want to
protect it. You could add a network firewall in front of the web app. The problem with using a network

firewall is that, while it's great at Layers 3-4, it does little to protect from attacks targeting the other Layers (5
7). This is where a Web Application Firewall (WAF) comes into play. For example, if an attacker launches an
HTTP flood attack on the web app, a regular network firewall can do little as it only sees legitimate HTTP
requests. A WAF, on the other hand, will inspect the traffic up to the application Layer (7).

What is email protection?

It’s a set of security measures to keep email accounts and communications safe from attacks like spam, phishing, and malware.

Key parts of email protection
1. Authentication & Verification

SPF (Sender Policy Framework) → checks if the email is sent from an authorized mail server.

DKIM (DomainKeys Identified Mail) → uses a digital signature to verify the email wasn’t altered.

DMARC (Domain-based Message Authentication, Reporting, and Conformance) → tells receiving servers how to handle emails that fail SPF/DKIM checks (reject, quarantine, or allow).

These three work together to stop email spoofing.

2. Anti-spam & Anti-malware filters

Block junk mail, phishing attempts, or dangerous attachments.

Use antivirus to scan emails for infected files.

IAM = Identity and Access Management ✅

It’s a framework of policies, tools, and processes that makes sure:

Who you are (identity) → is verified.

What you can do (access) → is controlled.

Key parts of IAM

Authentication → proving identity (passwords, MFA, biometrics).

Authorization → deciding what resources a user can access (roles, permissions).

User management → creating, updating, and disabling accounts.

Auditing → tracking who did what and when.

Why it matters

Without IAM, anyone could log in and access anything. With IAM:

Employees get only the access they need (least privilege).

Sensitive data stays protected.

Compliance with security standards (ISO, GDPR, HIPAA, etc.).

Examples

In AWS: IAM lets you create users, roles, and policies to control access to cloud resources.

In a company: IAM manages logins, permissions, and group memberships across apps (email, databases, VPN, etc.).

In short: IAM = the system that ensures the right people get the right access to the right resources at the right time.

Centralized Logging

What it is: Keeping all important logs (records of events, errors, and activities) in one place so you can monitor and audit your systems.

On-premise (your own servers):

You must install tools to collect logs from each machine and network device.

You also need to analyze these logs yourself.

Cloud (Azure, AWS, GCP):

The cloud provider already has logging systems built in.

Azure → Audit Logging

AWS → CloudWatch

GCP → VPC Flow Logs

These services let you search, filter, and even get automatic insights.

Analogy: Think of logs as security cameras. Centralized logging = putting all the camera feeds in one

ontainer Security

What it is: Making sure apps that run inside containers (like Docker or Kubernetes) are safe.

Containers: Packages that let apps run the same way everywhere (very portable and reliable).

On-premise:

You (the admin) must:

Configure containers securely.

Control how they connect to networks and the operating system.

Harden the environment to reduce risks.

Cloud (Azure, AWS, GCP):

They provide ready-made secure container environments.

Containers are provisioned (set up) automatically and secured by default.

This reduces mistakes and human error.

Analogy: Think of a container like a shipping container. On your own, you must build the locks and

Example: On-Premise IAM (Identity and Access Management)
1. Employees inside the office (on-premise)

Wired connection (network cable):

The computer plugs into the company network.

Uses 802.1X (a standard that says “prove who you are before using the network”).

The login (username/password or certificate) is sent to a RADIUS server.

The RADIUS server checks with the company directory (like Active Directory) to confirm the identity.

Wi-Fi connection:

Works the same way as wired → authenticate first → RADIUS checks identity → access granted.

2. Employees outside the office (remote)

They must first go through a firewall.

Then, they create a VPN connection (a secure tunnel into the company network).

After that, they authenticate:

Either with a password (Kerberos)

Or with multifactor authentication (MFA), like an RSA SecurID token (a small keychain that shows changing codes).

Key Access Control Terms

Digital Identity → Your online persona (e.g., your email login, bank account login).

One person can have many digital identities for different services.

Identification → Claiming who you are.

Example: Typing your username or user ID.

Problem: Anyone can type your username, so this alone is not enough.

Authentication → Proving who you are.

Done by providing credentials.

Methods fall into three categories:

Something you know → password, PIN.

Something you have → smart card, token, authenticator app.

Something you are → biometrics (fingerprint, face scan).

Authorization → What you're allowed to do after authentication.

Example: You log into your company account (authentication), but only HR staff are authorized to see payroll files.

Should follow the Principle of Least Privilege → give users only the minimum access they need.

Accountability → Tracking actions.

Identifies who did what and when.

Example: Security logs showing that "User123 deleted FileX at 3:15 PM."

The 3 Levels

IAL 1 – Self-Asserted (lowest assurance)

No real proof of identity is required.

The system just takes the user's word.

Example: Signing up with an unverified email or just entering your name.

IAL 2 – Evidence-Based (medium assurance)

Some evidence is required to link the applicant to a real-world identity.

Verification can be done remotely (e.g., email verification) or through a trusted third party (Credential Service Provider).

Example: Using a corporate email where the system trusts the domain and confirms ownership via a verification email.

IAL 3 – Physical Check (highest assurance)

Applicant must be physically present.

Identity verified by an authorized person using strong evidence (passport, government ID).

Example: Showing your passport in person before signing a contract and receiving credentials.

Single Sign-On (SSO)

The SSO technology allows a user to log on once with one set of credentials and use those credentials to
access different resources.

A common example is logging in via Facebook, Twitter, Microsoft or Gmail. This is done via the principle of
a single authentication service. On different platforms, you can use the same account without sharing your
credentials to that platform. In the next slide, we will discuss 2 types of authentication protocols that support
Single Sign on capabilities: SAML and Oauth.

How it works (example with Azure AD):

User clicks "Login with Microsoft" on an app.

The app sends an AuthnRequest (authentication request) to Azure AD (the Identity Provider).

Azure AD checks the user's identity (username/password, MFA, etc.).

If valid, Azure AD sends back a SAML Response → this is a time-limited token.

The app checks the token:

Is it from Azure AD?

Is it valid and unexpired?

If everything checks out → user gets access without entering another password.

1. **Discretionary Access Control (DAC)**

User decides who else can access something.

Access is based on credentials (like username/password).

Credentials can be shared at the user's discretion.

Examples:

A user giving someone else the password to a Word document.

Windows peer-to-peer networks.

Linux file permissions (you can choose who gets read/write rights).

Easy way to remember: DAC = "Discretionary = Decisions by the user."

2. **Mandatory Access Control (MAC)**

System decides, not the user.

Access is based on clearance levels (user) and classification levels (data).

Credentials cannot be shared or transferred.

Takes more work: every user must be assigned a clearance, and every piece of data must be classified.

Examples:

Military or government systems (Top Secret, Secret, Confidential).

You need the right clearance to open classified files.

Easy way to remember: MAC = "Mandatory = Managed by the system."

✅ Quick Comparison:

DAC → User can control/share access.

MAC → System enforces strict, non-shareable access.

3. **Role-Based Access Control (RBAC**)

Access is given based on a role or job function in the organization.

Users are grouped (e.g., "HR," "IT Admins," "Students," "Managers").

Each group/role has certain permissions → users inherit those permissions.

Example:

An HR employee has access to employee records.

An IT Admin has access to system settings.

A Manager may approve expenses but not change server configs.

Easy memory tip: RBAC = "Roles, not individuals."

2. Lattice-Based Access Control (LBAC)

A type of Mandatory Access Control.

Uses a lattice (hierarchy of security levels) to decide if a subject (user/process) can access an object (file/data).

Rule: A subject can only access an object if its security level ≥ the object's security level.

Can also use multiple factors like IAL (Identity Assurance Level) + AAL (Authenticator Assurance Level) to calculate a subject's security level.

Example:

A "Secret" user can read "Confidential" data but not "Top Secret" data.

A system calculates if your assurance level is strong enough before granting access.

Easy memory tip: LBAC = "Levels matter."

Account Administration – Enroll users, assign authenticators (e.g., passwords), and grant authorizations.

Maintenance – Regularly review and update accounts/permissions, especially when roles or duties change.

Monitoring – Log and review both successful and failed access attempts, focusing on sensitive resources.

Revocation – Promptly remove access when it is no longer needed (e.g., after termination).

Dictionary (wordlist) attack: Try each word from a list as a password candidate. Simple and fast against weak/common passwords.

Combinator attack: Like a dictionary attack but concatenates two words from the list (e.g., sun + shine → sunshine).

Brute-force attack: Tries every possible combination inside a keyspace. Guaranteed to find a password eventually but very slow for large keyspaces.

Mask attack: An optimized brute-force that uses a pattern (mask) to restrict the keyspace (e.g., password?d tests password0–password9), greatly speeding cracking when structure is known.

Hybrid attack: Combines a wordlist on one side with a mask (or generated suffix/prefix) on the other—useful when users modify common words (e.g., summer2023).

The Three Security Frameworks:

Let's look at three key frameworks that help organizations secure their systems: CIS Controls, NIST Framework, and MITRE ATT&CK.

CIS Controls (Center for Internet Security):

The CIS Controls are a set of 20 security controls (or actions) that organizations can follow to protect themselves from the most common and severe cyber threats. These controls are based on best practices that focus on preventing known attacks and mitigating future risks.

What makes it effective? The controls are designed to be practical and actionable. They cover basic cybersecurity tasks, such as making sure you have up-to-date patches, securing your network, and controlling user access.

Key Points:

20 controls: These include things like securing email, maintaining secure configurations, and performing regular vulnerability scans.

Automated Monitoring: Some of the controls can be monitored continuously with current technology (e.g., patch management, network monitoring).

Manual Controls: Others can’t be fully automated but are still crucial for defense (e.g., employee training, incident response planning).

Example: One of the CIS controls might be ensuring that all software is patched. This control can be tracked and monitored automatically to check if any software on your system is outdated or vulnerabl

NIST Framework (National Institute of Standards and Technology):

The NIST Cybersecurity Framework is a risk-based approach to managing cybersecurity. Originally created for critical infrastructure (like elections), it's used globally to help organizations defend against cyberattacks.

What's the structure of the NIST framework?

Framework Core: This is the heart of the framework and outlines the five key functions:

Identify: Understand the risks to your systems and assets.

Protect: Implement security controls to safeguard systems.

Detect: Monitor for potential cybersecurity events.

Respond: Plan and take action in case of an incident.

Recover: Restore and improve from any damage caused by an attack.

Implementation Tiers: These help organizations understand their cybersecurity maturity (how well they're implementing these core actions).

Profiles: Tailored to an organization's unique risk profile, helping them adjust the framework to fit their needs.

Key Points:

The framework is risk-based, which means it helps organizations assess and prioritize which risks they need to address first.

It's flexible and can be used by any organization, not just those in critical infrastructure.

Example: A local election office could use NIST to understand their cybersecurity risks, implement measures to protect election data, and prepare a response plan if they're attacked.

3. **MITRE ATT&CK Framework**:

The MITRE ATT&CK™ Framework is a knowledge base that details how cyber attackers (adversaries) carry out their attacks. It’s a list of tactics and techniques that hackers use, based on real-world observations.

What does it include?

Tactics: These are the high-level goals of an attacker (e.g., "Initial Access", "Execution", "Exfiltration").

Techniques: These are specific ways the attacker tries to achieve their goals (e.g., phishing emails for "Initial Access").

The framework helps organizations understand how cyberattacks unfold so they can better defend against them.

Key Points:

Adversary Tactics and Techniques: It shows the specific steps attackers take, which helps organizations recognize and counter them.

It’s constantly updated based on new, real-world attack techniques.

Example: If an organization sees a spike in phishing attempts, they can reference the MITRE ATT&CK framework to learn about the attacker’s typical next steps (e.g., credential dumping, lateral movement) and adjust their defenses accordingly.

MITRE ATT&CK is a framework used by cybersecurity professionals to understand how attackers operate, what tools they use, and what techniques they apply to breach and attack systems. It helps organizations detect, respond, and defend against cyberattacks more effectively. Here's an easy breakdown:

1. Tactics

Tactics represent the goals or objectives that attackers aim to achieve during their attack. It's like the "big picture" of what they are trying to do.

For example, "Initial Access" is a tactic where attackers try to get into your system, and "Persistence" is about making sure they stay in your system.

2. Techniques

Techniques are the specific methods or ways attackers use to achieve those goals (tactics). It’s like the strategy they use to accomplish their objective.

For example, a technique under the "Initial Access" tactic could be using "Phishing" to trick someone into giving up their credentials.

3. Sub-techniques

These are more specific variations of a technique. They dive even deeper into how exactly an attacker might carry out a particular technique.

For example, phishing could involve sending a malicious email or compromising a website to steal credentials.

What Does MITRE ATT&CK Provide About Each Technique?

For each technique, MITRE ATT&CK tells you:

How it's done: A detailed explanation of how attackers use this technique.

How to detect it: What signs or behaviors you should look for to detect it.

Mitigations: Tips on how to block or reduce the risk of this attack technique.

Example Adversaries: Which known hacker groups or campaigns use this technique.

Example: The "Valid Accounts" Technique (T1078)

Tactic: Initial Access (gaining access to the system)

Technique: "Valid Accounts" (attackers use stolen or compromised credentials to log in)

Details: MITRE ATT&CK describes how attackers use valid credentials to log into systems, and how organizations can detect this behavior (e.g., monitoring for unusual logins).

Mitigation: Organizations can prevent this by configuring strong account activity policies, auditing account behavior, and using multi-factor authentication.

How Does MITRE ATT&CK Help?

Threat Intelligence: You can map the techniques to known adversary groups (hackers) and see if they've used the same tactics against others.

Defense & Detection: It helps cybersecurity teams detect attacks early by understanding these tactics, techniques, and behaviors

Data Loss

Data loss occurs when data is being corrupted, deleted or made unreadable in any way.

Data Leakage

In most cases, data leakage is categorized as a security incident that results in data being accessed in an unauthorized way. One of the typical examples is exposing data on publicly available sites by using external sharing platforms.

Example: Ransomware

Ransomware is a variety of malware that, upon infecting a system, encrypts all the data on the hard drive it can find. Subsequently, the user of the system is prompted with a screen explaining what has happened and a ransom note requiring them to pay a certain amount of money, often in the form of a cryptocurrency like Bitcoin (BTC) in order to get their data back. More often than not, even after payment, the user does not get a way to retrieve their data, and the data is lost forever.

While intentional malware attacks make up a certain portion of data loss cases, most of the time, data loss is attributed to unintentional deletion of data. Accidental destruction of the device

Prevention Strategies (1)

Data loss can be prevented in a number of ways. This slide presents an overview of prevention strategies.

Redundancy and backups are technical measures an organization can take to prevent data loss.

Access control is a combination of strategic and technical measures an organization can take to prevent data loss. By ensuring a user can only access, modify, or delete data on a need-to-have basis, the risk for accidental deletion is lowered significantly. This is one of the most important mitigation techniques to prevent unintentional data loss due to human erro

What is ECC Memory?

ECC memory is a specialized type of RAM that can:

Detect and correct single-bit errors automatically

Detect (but not correct) multi-bit errors

This is crucial in systems where data accuracy is essential, like servers, scientific computing, financial systems, and critical databases.

How ECC Memory Works

ECC RAM includes extra bits for every byte of data, which store error-detecting and correcting codes (usually Hamming code or similar).

Example:

Regular RAM might store 64 bits of data.

ECC RAM stores 72 bits: 64 data bits + 8 ECC bits.

Error-Correction Code (ECC) memory adds some extra bits to each data unit, enabling the system to detect
if a bit in the data has been changed accidentally and to correct the issue. It is often used in computer systems
that do not tolerate memory corruption, such as financial computing.

Why Use RAID?

Hard drives can fail — and when they do, data can be lost. RAID helps prevent this by:

Storing copies of data on more than one disk (redundancy)

Splitting data across disks to improve speed (called striping)

Adding parity bits for error detection and sometimes correction

Key RAID(Redundant Array of Independent Disks) Concepts
1. Redundancy

Data is copied to multiple drives so if one drive fails, you don’t lose your data.

2. Striping

Data is split into chunks and written across multiple drives at once. This increases performance, because the system can read/write from multiple disks at the same time.

Example:
If you have 3 drives, the first chunk of a file goes to Disk 1, the second to Disk 2, and so on.

3. Parity

Parity bits are extra bits added to help detect (and sometimes fix) errors.

A parity bit is used to indicate whether the total number of 1s in a binary group is even or odd.

If one drive fails, the system can rebuild the lost data using the parity information.

Redundant Data in the Filesystem

Redundancy doesn't only come from hardware (like RAID); it can also be built into the filesystem — the part of the operating system that manages files and storage.

Example: Journaling Filesystems

A journaling filesystem keeps a log (journal) of actions it's about to take. This log acts like a "to-do list" for the disk.

How It Works:

Before making any changes (like writing or deleting a file), the system writes an entry to the journal.

Then it does the operation (write/delete/modify).

If the system crashes (e.g., power failure), the journal can be used to replay or undo the operation.

Why It Matters:

Prevents file corruption during a crash.

Helps the system recover quickly to a consistent state.

✅ Common journaling filesystems:

ext3/ext4 (Linux)

NTFS (Windows)

HFS+ / APFS (Mac)

Cloud Redundancy Explained

Cloud redundancy is the practice of ensuring your data is safe, available, and recoverable even when part of the cloud infrastructure fails. This is done using replication between storage nodes (virtual storage units backed by physical drives in a data center).

How Cloud Redundancy Works
Storage Node Replication

Data is copied to multiple storage nodes.

If one node fails, data is retrieved from another.

Helps ensure data availability and prevents data loss.

Admin Control: Setting N Replicas

Admins can configure a setting to ensure data is stored on at least N nodes.

Guarantees that N copies of each file exist, improving reliability.

Data Integrity Checks

When reading data, the system can compare values from multiple nodes to make sure nothing is corrupted.

This is a form of consensus, similar to a voting system between replicas.

Geo-Replication

Data is replicated across different geographic regions.

Protects against regional disasters (earthquakes, power outages, etc.).

Tradeoff: Integrity/Availability vs Performance

Cloud systems often face a balancing act:

High redundancy (many replicas) ensures reliability, but slows down writes.

High performance might reduce replication and risk data loss if something fails.

CAP Theorem (for Distributed Systems)

A system can only have 2 out of 3 properties at the same time:

Property	Meaning
Consistency	All nodes see the same data at the same time
Availability	Every request gets a response, even if some nodes fail
Partition Tolerance	The system continues to work even when parts of it can't communicate

You must choose which two to prioritize.

For example, if you choose Consistency and Availability, you sacrifice Partition Tolerance — the system must wait for all replicas to sync, which slows things down during failures

Backup Methods Explained

1. Full System Imaging (Full Backup)

What it is:

Makes a complete copy of everything: the operating system, files, applications, settings — the entire system.

Stored as a single image file.

Pros:

Easy to restore — everything is in one place.

Most reliable for full system recovery.

Cons:

Takes a lot of storage space.

Slow to perform, especially for large systems.

2. Incremental Backups

What it is:

Backs up only the data that changed since the last backup (either full or incremental).

Example:

Monday: Full backup

Tuesday: Incremental backup (only changes since Monday)

Wednesday: Another incremental (only changes since Tuesday), and so on.

Pros:

Very space-efficient.

Fast to run after the first backup.

Cons:

Restoring takes longer — you need the full backup plus all incremental backups in sequence.

If one piece is missing or corrupted, restoration may fail.

3.Differential Backups

What it is:

Backs up everything that changed since the last full backup — not since the last differential.

Example:

Monday: Full backup

Tuesday: Differential backup (changes since Monday)

Wednesday: Differential backup (also changes since Monday), etc.

Pros:

Faster restore than incremental — you only need the full + one differential.

Each differential is independent of the others.

Cons:

Grows in size over time until a new full backup is made.

More storage than incremental but less than full.

4.Continuous Backups (Real-Time or Near Real-Time)

What it is:

Automatically backs up data whenever a change is made.

Often done in short intervals (e.g., every 5 minutes), not literally every micro-change, to reduce system load.

Pros:

Can restore data to any point in time, or to the last few minutes.

Ideal for mission-critical systems.

Cons:

Requires a lot of storage and computing resources.

More complex setup.

Can add system overhead if not optimized.

Backups: Common Pitfalls

Keep backups on separate networks
When a system is infected with ransomware (or other malware), there's a large chance the malware will
look for network devices and propagate to them as well

Data Recovery
The 4 Main Steps of Data Recovery

Repair the Storage Device

If the device (like a hard disk) is physically damaged, it's first repaired so it can work again.

For example, technicians might take the data disk (platter) out of the broken drive and put it into a working one — but this must be done in a clean room (dust-free area), or the data can be destroyed.

Copy (Image) the Data to Another Device

After the device is working again, all its data is copied (imaged) to another healthy drive.

This is important because the damaged device might fail again — so recovery work is done on the copy, not the original.

Fix Logical Errors

Sometimes the file system (the way data is organized) is corrupted.

Technicians repair the file system so the data can be accessed properly.

Repair or Recover the Files

Once the files can be opened again, some may still be damaged.

Recovery tools or manual repair are used to restore them as much as possible.

Why Is Data Leakage Prevention Important?

-Business Losses
- Reputational Damage(السمعه)
-Fines
In many jurisdictions, certain types of data are protected by legislation, such as GDPR for European
data protection, HIPAA for the US health sector, and Sarbanes-Oxley (SOX) and Gramm-Leach
Bliley Act (GLBA) for the US financial sector, among others. The leakage of said data may lead to
high fines for the organization—under GDPR, for example, fines go as high as 4% of the global

revenue of a company at group level. We'll go over some sample regulations in the following slide

GDPR & CCPA

General Data
Protection Regulation ("GDPR"), is a European law
enacted in 2016 that outlines data protection measures that
need to be taken when an organization collects and processes
personal data.

Article 32 – Keeping Data Secure

Companies must take good security steps to protect personal data.
That includes:

Hide or encrypt data

Use methods like encryption or pseudonymization (replacing real names with fake ones).

Keep systems safe and working

Make sure systems are always protected, available, and can handle attacks or failures.

Be ready to recover data

If something breaks or data is lost, they must be able to restore it quickly.

Test security regularly

Check and improve their security systems often to ensure they still work well.

Article 33 – Report Data Breaches Quickly

If a company finds out that personal data was leaked or hacked:

They must report it to the authorities within 72 hours (3 days).

They don’t have to report it if the breach isn’t likely to harm people.

Article 34 – Inform the People Affected

If the data breach is serious and could harm people (for example, identity theft or financial loss):

The company must tell the people whose data was exposed.

The message should be clear and simple, explaining what happened and what is being done to fix it.

CCPA (California Consumer Privacy Act)

This is a similar law in California (USA).
It also protects people's personal data and lets them take action if a company doesn't protect it properly.

CCPA 1798.150 – If a Company Fails to Protect Data

If a company doesn't secure your personal data and it gets stolen or leaked:

You can sue the company and ask for money:

Between $100 and $750 per person per incident, or more if the real damage is higher.

You can also ask the court to:

Order the company to fix its security (injunctive relief).

Or take other actions the court finds fair

Storing Sensitive Data

1- Sensitive data should always be stored with strong encryption

2-Sensitive data should be securely deleted when it is no longer needed

What Are DLP Policies?

DLP (Data Loss Prevention) policies are rules made to stop important data from leaking or being lost — whether it's being stored (at rest) or sent somewhere (in transit).

They help protect things like:

Personal information (like credit card or ID numbers)

Company secrets

Financial or customer data

How DLP Policies Work

DLP tools let an administrator set rules (policies) that tell the system:

Where to watch

What to look for

What to do if it finds something

1. Locations — Where to Watch

This means where the DLP system should look for sensitive data.
Examples:

Company servers or computers

Cloud storage (like Google Drive, OneDrive)

Email systems

Specific folders or databases

Sometimes, it's grouped more generally:

"Secure" locations

"Encrypted" storage areas

Example:

Watch all outgoing emails and files saved on laptops.

2. Conditions — What to Look For

This defines what kind of data or situation the DLP tool should detect.

Examples:

Files with labels like “Confidential” or “Secret”

Files shared with outside users

Documents containing:

Credit card numbers

Social Security numbers

Passwords or financial data

Example:

If a file contains a credit card number or is shared with someone outside the company — trigger the rule.

3. Actions — What to Do

This defines what happens when the DLP system finds something risky.

Common actions:

Alert security staff

⛔ Block sending the file or email

Restrict access to the data

Watermark the file (“Confidential”)

Delete or move the file to a safe place

Ask for manager approval before sending data

Change or suggest a new classification (e.g., from “internal” → “confidential”)

Example:

If someone tries to email a confidential file outside the company → block it and alert the admin.

What Are Data Classification Labels?

Data Classification Labels are tags (or categories) that tell how sensitive a piece of data is and how it should be protected.

They help companies decide what security rules apply to different types of data. For example, not all files need the same level of protection — some are secret, others are public.

How It Works

Every file or piece of data gets a label (like “Secret” or “Public”).

The data owner (person responsible for that data) usually chooses the label.

Sometimes, the DLP tool can suggest a label automatically — for example, if it finds personal info like credit card numbers, it may suggest “Confidential”.

Why It’s Important

If everything is marked “Confidential,” employees stop taking it seriously.
So, companies should:

Use clear, simple labels

Make sure everyone understands what each label means

Monitor and enforce correct labeling with DLP tools

1. Data At-Rest (Stored Data)

“At-Rest” means data that is saved or stored somewhere — for example on a hard drive, server, cloud storage, or email system.
DLP (Data Loss Prevention) policies protect this stored data from being exposed, stolen, or stored incorrectly.

Simple Examples

Automatic Encryption

The DLP tool automatically encrypts sensitive files (like ones with Social Security Numbers or personal info).

Example: “If a file contains employee data → encrypt it using AES-256.”

Fix Wrong Classifications

The DLP system checks if files have the right sensitivity label (like “Public,” “Internal,” or “Confidential”).

If a file is marked “Public” but contains credit card numbers, the DLP tool can:
→ Suggest changing its label to “Confidential.”
→ Or alert the file owner.

Detect Data in the Wrong Place

If sensitive data is found in an unsafe location (like a public folder), the DLP tool can:
→ Alert security staff,
→ Move the file to a secure folder,
→ Or even delete it automatically.

Example in Plain Words

The DLP tool scans your company’s servers for files with Social Security Numbers.
If it finds any that aren’t marked “Confidential,” it sends an email to the owner suggesting to fix the label — and encrypts the file automatically.

2. Data In-Transit (Moving Data)

“In-Transit” means data that is being sent or transferred — for example by email, file upload, or through the internet.

DLP tools monitor and protect this data as it moves from one place to another to prevent leaks.

Simple Examples

Detect Sensitive Data Being Sent

The DLP tool watches outgoing emails or file transfers.

If it detects sensitive or unencrypted data (like medical info under HIPAA), it can take action.

Possible Actions

Ask manager approval before sending the data.

Block the email or transfer completely.

Alert the security team immediately.

Remove the sensitive part (like credit card numbers) before the message is sent.

Example in Plain Words

Suppose your company sends customer medical data by email.
If someone tries to send it unencrypted to an address outside the company:

The DLP system blocks the email,

Warns the sender to encrypt the file,

And alerts security staff.

Another example:

If an email contains a “Confidential” document, the DLP tool notifies the security officer and asks for approval before the email is sent.

Data Loss Prevention Tools
We have listed some examples of popular Data Loss Prevention (DLP) tools that are frequently used by
organizations:

1. DigitalGuardian
2. Forcepoint
3. Office 365 Data Loss Prevention

Should You Store All Your Data Online?
Data that is offline is hard to steal. Data that is stored on media that is not connected to a server simply cannot
be accessed without connecting the media to a server, or stealing the media—in other words, it requires
physical access to the media. However, most advanced adversaries attack your enterprise via digital intrusion
(remotely): They have no physical access to the IT assets of your corporation and, thus, can only access online
data.

What Does “Data to Keep Offline” Mean?

Some data is so sensitive that it should never be connected to the internet or any network — it must be kept completely offline to protect it from hackers.

A great real-world example of this is how Certification Authorities (CAs) handle their private keys in a Public Key Infrastructure (PKI) system.

What Is a PKI (Public Key Infrastructure)?

PKI is a system used to create and manage digital certificates — the same ones that make websites secure (the "https" you see in your browser).

It uses two main parts:

Public key → shared with everyone.

Private key → kept secret and used to digitally "sign" things.

If a private key gets stolen, an attacker can pretend to be that company or website — which is very dangerous!
That's why some keys are kept offline.

The PKI Pyramid

The PKI system works like a pyramid with three levels of certificates:

Level Name Validity Purpose Where Stored
Root CA Root Certificate ~30 years Used to create and sign intermediate certificates. Kept offline (on a USB or hard drive in a safe).
Intermediate CA Intermediate Certificate ~10 years Used to issue certificates for users, servers, etc. Stored securely (often on a Hardware Security Module).
Client Certificates End-User Certificates 1–3 years Used by websites, users, or devices. Regular use — kept online.
How It Works (Step by Step)

The Root Certificate (top of the pyramid)

Created once, valid for a very long time (e.g., 30 years).

Has its own private key, which is used only to sign intermediate certificates.

After that, it's locked away offline — on a removable drive in a safe.

The Intermediate Certificate

Valid for a shorter time (e.g., 10 years).

Used to issue client or server certificates (for websites, etc.).

The private key is stored in a Hardware Security Module (HSM) — a special device that can use the key to sign data but never reveals it.

Client Certificates

These are for everyday use — valid for 1–3 years (e.g., for websites).

Signed by the intermediate CA.

Network IDS is done by monitoring traffic on the organization's network by passively looking at the packets
that are passing through. We speak of online network IDS when the system runs in real time and analyzes all
traffic as it is passing by the detection system by applying basic detection rules to the packets. On very large
networks, a massive amount of data is passing by the system simultaneously

A Host IDS (Host Intrusion Detection System) watches over a single computer or device to make sure nothing suspicious is happening on it.

Here's what it does in simple terms:

It records what's happening on the computer — things like changes to settings, strange activity, or new programs being run.

It also uses antivirus tools to look for known malware (bad software).

The system takes a "snapshot" of how the computer looks right now (its files, settings, etc.), and later compares it to an older snapshot.

If it notices unexpected changes — for example, new files, missing security settings, or unknown programs — it raises an alert.

What is Data Exfiltration?

Data exfiltration means stealing data from a computer or network and sending it out secretly to the attacker.
It usually happens after a hacker has already broken into a system.

Step-by-step explanation:
Step 1 – Searching for data

Once hackers get inside a system, they don't immediately know where the important data is (like passwords, customer data, or company secrets).

So, they start searching around the network for interesting files.

While doing this, they may make mistakes or cause errors (for example, trying to open files they don't have permission for), which can help defenders detect them.

Step 2 – Collecting and preparing data

When they find interesting files, they gather them all into one place — like putting everything into one folder.

They usually take a lot of data, such as someone's whole email inbox or entire databases.

To make it easier to steal, they compress (zip) the files and sometimes encrypt them so others can't see what's inside.

This step helps them organize the data before sending it out.

Step 3 – Sending data out (Exfiltration)

The hackers then try to send the stolen data out through the company's internet connection.

This could be done quietly over the network, so it doesn't attract attention.

In rare cases, if they have someone physically present, they might copy the data onto a USB drive, but that's uncommon.

How easy this is depends on the network design:

If the company's network is flat and open, it's easy for hackers to move data out.

If the network is well-segmented (divided into secure parts), it's much harder for attackers to steal large amounts of data.

1. PREVENT — Stop it before it happens

These are actions to make it hard for attackers to steal data in the first place.

✅ a) Know your data

The organization must know what data it has and how important or sensitive each type is.
(For example, employee info, financial records, etc.)

This process is called data classification.

✅ b) Limit access (Need-to-know)

Users should only have access to the data they need for their job — nothing more.
(So if someone works in HR, they shouldn't see finance files.)

✅ c) Store data safely

Think about where and how you store important data.

Use network segmentation — dividing the network into smaller, secure zones — so if one area is hacked, the rest stays safe.

For very sensitive data, you might even store it offline (not connected to the internet).

Goal: Reduce how much data an attacker could reach or steal if they break in.

2. DETECT — Catch it if it happens

These are actions to notice if someone is trying to steal data.

✅ a) Watch for suspicious searches

When attackers look for files, their searches create a lot of activity on the system.
(They open many folders and files — sometimes thousands.)

This activity can be "noisy" and might stand out.

✅ b) But be careful — there can be false alarms

Normal programs like antivirus, backup tools, and search indexers also scan many files.
These can look similar to an attacker's search but are harmless.

✅ c) Monitor access to shared files

You can monitor network shares (shared folders used by many users).
In Windows, look for Event ID 5140 — "A network share object was accessed."

If you see repeated failed access attempts from the same user or computer, that could mean someone is trying to find data they shouldn't.

What are Decoy Files or Honeypots?

Decoy files (also called honeypots) are fake files or systems that look valuable to attackers — but actually, they're traps.

They are designed to attract hackers by having interesting names like "top-secret-project.docx" or "passwords.xlsx."

These files don't contain real data, but they are heavily monitored.

If anyone tries to open or copy them, the system immediately raises an alert, because a normal, trusted user would never need to touch them.

Insider Threats

Most of the time, when we think about potential attackers, we always imagine an adversary from outside the
organization. Quite often, however, a threat comes from within. According to the 2016 US State of
Cybercrime Survey, about 27% of reported

What is an Insider Threat?

An insider threat means a risk that comes from within the organization — from someone who already has authorized access, like:

Employees

Contractors

Partners

These people can accidentally or intentionally harm the organization by leaking, stealing, or damaging information.

Step 1: Build an Insider Threat Program

To deal with insider threats, organizations need a special program called an Insider Threat Program.

This program helps:

Detect risky behavior early,

Reduce chances of data leaks,

Create awareness among employees.

Step 2: Raise Awareness

Everyone in the organization should know that this program exists.

When employees are aware, it discourages (or deters) people from leaking information — because they know they can be caught.

It also helps create a positive culture, where employees report suspicious activity and act in the company's best interest.

Step 3: Work with HR (Human Resources)

The security team and the HR department must work together.

HR is close to the employees and can notice warning signs, like when someone is:

Unhappy with their job,

About to be fired or leave,

Acting strangely around sensitive data.

When HR reports these risks, the security team can increase monitoring on that person to prevent data theft.

Important:
If someone is under investigation, only HR and security staff should know.
Other coworkers should not be told, to keep things private and professional.

Step 4: Encourage Good Behavior

Research shows that using positive incentives (like rewards, trust, or recognition) encourages employees to:

Follow security rules,

Protect company data,

Report suspicious actions.

What is User Activity Monitoring (UAM)?

User Activity Monitoring (UAM) means watching what users do on company computers and systems to make sure they're not doing anything suspicious or unauthorized.

Digital watermarking means adding hidden or visible marks inside digital data (like documents, images, videos, or printouts) to show who owns it or where it came from.

It's like putting a signature or fingerprint on digital files.

How it works:

A digital watermark is embedded into a file — sometimes visible (like a logo or text), and sometimes invisible (hidden inside the data so you can't see it).

Later, if that file is leaked or stolen, the watermark can help trace it back to its source.

Watermarks don't stop leaks, but they help find out who leaked the information.

They can be:

Visible → like "© Company Name 2025" written on a photo.

Invisible → hidden patterns or codes inside the file.

Android Security Features

Application Security

Applications are rigorously tested for security before they are available for download

Active Scanning

When applications run, they are monitored to look for suspicious activity

Android Pay
Secure payment options do not expose credit card data

Virtual Sandbox
Critical data is sandboxed or isolated from applications to minimize exposur

Device Manager
Allows for locating and securely wiping remote devices

Built-in Encryption
Cryptographic functionality is built in to protect data at rest and in transit

How it works

When you install an app (like WhatsApp or TikTok), the phone creates a sandbox just for that app.

Inside that sandbox:

The app can store its data (messages, images, etc.)

It can't directly access another app's data (like your banking app).

It can only use phone features (camera, location, contacts, etc.) if you give permission.

So even if one app is hacked or infected with malware, it can't escape its sandbox to damage your whole phone.

Example

Let's say you download a game:

The game runs in its own sandbox.

It can only use the files and memory inside that sandbox.

If it tries to read your WhatsApp chats or photos, Android/iOS will block it, unless you give permission

What You Need to Know About Android

1. Who controls Android

Android is created and led by Google.

It's part of a group called the Open Handset Alliance, which includes phone makers like Samsung, LG, etc.

2. Why Android is "open"

Unlike Apple (which controls everything on iPhones), Android is open-source.

This means any company can use and change Android for their own phones or tablets.

3. What manufacturers do

Companies like Samsung, Huawei, and Xiaomi take the basic Android system and customize it.

They add their own apps and designs (like Samsung's One UI).

They remove things they don't want.

They sometimes limit access to make users keep their software.

4. Why phones are different

Because every company changes Android in its own way, phones:

Look different

Have different features

May not work with all apps the same way

This is called Android fragmentation.

Android Fragmentation — What It Means

“Fragmentation” means there are many different versions of Android running on different phones.

1. Why fragmentation happens

Many different manufacturers (OEMs) make Android phones.

They make money from selling phones, not from keeping old ones updated.

So they focus on new phones, not updating old ones.

2. Each company customizes Android

Each brand changes Android to make their phones unique — new skins, new apps, special features.

Example: Samsung adds Samsung Knox, One UI, and SmartThings.

3. Updates are complicated

Google releases a new Android version →

The phone company (like Samsung) changes it for their devices →

The mobile network (like Vodafone or AT&T) decides whether to send it to users.

This chain causes delays or no updates at all.

4. Old phones stay old

Many phones in stores are older models still being sold cheap.

They don’t get updates — so users are stuck on outdated Android versions.

Security Problems Caused by Fragmentation

Many phones don’t get security updates quickly (or at all).

Hackers can attack phones with known bugs that haven’t been fixed.

Users miss new features for months or even years.

Apple iOS Security
What You Need to Know About iOS Security
1. Closed Model

Apple uses a closed system, which means only Apple controls the hardware and software.

You can’t change or customize iOS like Android.

The only way to change deep system settings is to jailbreak the iPhone — and that’s not safe and not supported by Apple.

Example:
You can’t install your own version of iOS or remove Apple’s security settings.

2. Security Built Into Everything

Apple designed security into every layer of the iPhone:

Hardware (the chip itself)

Operating system (iOS)

Apps and App Store

Network and storage

So, protection starts the moment you turn on the phone.

3. Startup Security Check

When you power on an iPhone, it automatically checks if iOS has been changed or hacked.

If something’s wrong, the phone won’t start properly — this stops malware from taking control early.

4. Transparent Security

iOS does most of the security work automatically, so the user doesn’t have to do anything.

You don’t see it, but it’s always happening in the background — like:

Checking app signatures

Protecting system files

Managing permissions

Encrypting data

This means security is invisible but always active.

5. Security Cannot Be Turned Off

Important features like encryption (which protects your data) are always on.

You can't disable them — even if you wanted to.

That makes iPhones safer because users can't accidentally weaken their own security.

Apple iOS Security Features (Simple Explanation)

Apple designed iOS with several layers of security to protect your phone, your data, and your apps.
Here's what each part means

1. System Security

Security is built into both the hardware (the chip) and the software (iOS).

From the moment you turn on the phone, it checks that everything is safe and not modified.

This protects the entire system — the base that all apps run on.

✅ Example:
If someone tries to install a fake iOS version, the phone will detect it and refuse to start.

2.Encryption and Data Protection

This protects your personal data (photos, messages, passwords, etc.).

If your iPhone is lost or stolen, no one can open or read your data without your passcode or Face ID.

Data is encrypted ("locked") while stored on the phone — this is called data at rest protection.

✅ Example:
Even if a hacker takes out your iPhone's memory chip, the data still looks like random numbers — unreadable without the encryption key.

3.Network Security

Protects data while it’s being sent or received — this is called data in transit.

iOS uses secure connections (like HTTPS, VPN, and encrypted Wi-Fi) to stop hackers from spying on your internet traffic.

✅ Example:
When you send a message or log in to a website, your information travels encrypted so no one can steal your password.

4. Application Security

iOS controls how apps work on your phone to keep them safe.

Every app runs in its own sandbox — it can’t touch or read another app’s data.

Apps must be approved by Apple before going to the App Store, reducing malware risk.

✅ Example:
A game app can’t secretly read your banking information or messages because of sandboxing.

Apple iOS Security Features (2)

Apple Pay: Enables you to make secure payments by registering the device with the credit card
issuer. Based on the negative impact of payment information, it is critical that proper security is
wrapped around and integrated into payment capabilities

Internet services: Provide cloud-based services for backup and capability for communication. On
a daily basis, most people are texting, syncing, or backing up their devices

Device control: Enables management of a device to include secure wipe. Apple devices often
need to be controlled remotely.

Privacy controls: Enable you to share device information with external services, such as location
services. Information needs to be pulled from a device, such as the location, and it is important
that it is only for authorized use

What You Need to Know About iOS (Simple Explanation)

1. Very Popular Platform

iOS is used on iPhones, iPads, and iPods.

It’s popular with both:

Companies (enterprise-owned) → for work phones

Regular users (user-owned) → personal use

So, iOS is found everywhere — from offices to homes.

2. More Restrictive Than Android

iOS is closed and tightly controlled by Apple.

You can’t easily change the system, install unapproved apps, or customize it like Android.

This restriction makes iOS more secure and stable, but gives users less freedom.

✅ Example: You can only install apps from the App Store, not from the web.

3. End-to-End Control by Apple

Apple controls everything:

The hardware (the iPhone itself)

The software (iOS)

The App Store

This full control helps Apple make iPhones faster, safer, and more consistent.

✅ Example: Apple designs the iPhone chip, the iOS system, and the security features — all to work perfectly together.

4. No Mobile Operator (MO) Software

Apple does not allow mobile carriers (like Vodafone, AT&T, or Orange) to install their own apps or modify the iPhone’s software.

This keeps iOS clean and prevents unwanted apps or security risks from carriers.

✅ Example: On some Android phones, you see preinstalled apps from your carrier — but not on iPhones.

5. Little Difference Between Devices

iPhone, iPad, and iPod all run the same iOS system (with small differences).

So apps and updates work almost the same way across all Apple devices.

✅ Example: The Messages app or Safari browser works the same on an iPhone and an iPad.

6. Constant Hardware Improvement

Apple keeps improving iPhone hardware — faster chips, better cameras, stronger security (like Face ID).

New hardware = new software features

Example: Face ID only works on devices with the TrueDepth camera.

Mobile Problems and Opportunities (Easy Explanation)
1. Mobile Devices = Both Good and Bad for Organizations

Mobile phones and tablets bring new challenges but also new benefits to companies. They make work faster and easier — but they also create security risks.

2. How Users See Mobile Devices

People love mobile devices because they're:

Modern

Powerful

Convenient

Employees often believe phones and tablets help them work faster and stay connected.

✅ Example: Workers use phones for emails, meetings, and quick communication — even outside the office.

3. From a Security Point of View

Security experts see mobile devices very differently.
They often find that mobile devices:

❌ Lack advanced security tools that normal computers have.

Have weak enterprise controls, meaning it's harder for companies to manage and secure them.

Can't be fully controlled by IT teams (users install their own apps, connect to any Wi-Fi, etc.).

So while phones are powerful, they're not as secure as laptops or desktops.

4. Why Organizations Still Use Them

Even though mobile devices can be risky, companies can't just ban them because:

Employees will still use their phones for work — even without permission.

Phones make business faster and more flexible.

Mobile technology can help in many industries (healthcare, sales, education, etc.).

✅ Example: A salesperson can check inventory or send invoices right from their phone — saving time.

5. Banning Mobile Devices Is Not the Solution

If a company says "No phones allowed," employees often:

Use their personal phones anyway

Connect to company email or files without approval

Bypass security rules

This actually increases risk, because IT teams lose control and visibility.

6. ✅ Better Solution

Instead of banning mobile devices, companies should:

Allow them safely under management and monitoring

Use Mobile Device Management (MDM) systems to:

Track devices

Control app installations

Protect company data

This way, organizations can enjoy the benefits of mobile tech without too much risk.

Threats We Actually Care About (Mobile Security)
TH1 — Loss of Control and Visibility with BYOD

BYOD = Bring Your Own Device (employees use their personal phones for work).

Problem:

The company doesn't fully control personal phones.

IT can't see what users install, who they share data with, or whether the device is secure.

Company data can mix with personal data, causing privacy and security risks.

✅ Example:
An employee's personal phone has company emails — if it's infected with malware or lost, company info may leak.

TH2 — Always-On Devices with Many Interfaces

Phones are always connected — through Wi-Fi, Bluetooth, mobile data, NFC, GPS, etc.

Problem:
Each connection is a possible attack point for hackers.
The more connected features a phone has, the more ways someone could attack it.

✅ Example:
A hacker could exploit Bluetooth, a public Wi-Fi network, or a rogue app to steal data.

TH3 — Device Patching and Long Vulnerability Periods

Patching = installing updates that fix security problems.

Problem:
Many phones, especially Android ones, don't get updates quickly (or at all).
This leaves devices vulnerable for long periods — known bugs remain open for attackers.

✅ Example:

If a phone hasn't been updated for months, a hacker can exploit an old weakness to gain access.

TH4 — Device Theft and Loss

Phones are small, valuable, and easy to lose.

Problem:
When a phone with company data is lost or stolen, someone else might access:

Emails

Files

Passwords

Contacts

If there's no encryption or screen lock, data can be easily stolen.

✅ Example:
A stolen phone with company files becomes a data breach if it's not protected.

TH5 — Weak Server-Side Controls

Even if the phone is secure, the servers or apps it connects to might not be.

Problem:
If the backend systems (like company servers or cloud apps) are not well-protected, attackers can:

Steal data directly from the server

Bypass phone security altogether

✅ Example:
A hacker doesn't need to hack your phone if they can hack the cloud account your phone connects to.

Unlocking, Rooting, and Jailbreaking
Simple Idea:

All mobile phones (Android, iPhone, Windows, etc.) are locked down by their manufacturers to protect users and the system.

These restrictions control things like:

✅ Which apps you can install (only from official stores)

✅ What parts of the system you can change

✅ Whether apps must be code-signed (approved and verified by Apple/Google)

What These Terms Mean

Term	Platform	What It Does	Result
Jailbreaking	iOS (Apple)	Removes Apple's restrictions	You can install unapproved apps, change system files
Rooting	Android	Gives you "root" (admin) access	Full control of phone, bypassing built-in limits
Unlocking	Windows / or carrier unlocking	Removes restrictions (e.g., carrier lock or system limits)	Lets you use any SIM card or custom software

Why People Do It

To customize their phone's look and behavior

To install apps that aren't allowed in the App Store or Google Play

To analyze apps or perform security research

To remove bloatware (pre-installed apps)

Why It's Dangerous

Removes built-in protection — makes your phone easier to hack.

Allows unverified apps — malware can install silently.

Voids warranty — manufacturer support may be lost.

No automatic updates — security patches may stop working.

Data theft risk — root access = total control for an attacker.

✅ Example:
If a hacker tricks a user to install a malicious app on a rooted phone, that app can read messages, passwords, and system files that are normally protected.